

零基礎也看得懂的踩雷版 Checklist

使用說明

這份表不是考你技術，而是幫你檢查：「我現在做的這個東西，是玩具等級，還是可以拿給別人用的東西？」

請沿著每一個「坑」往下看，遇到符合自己的，就認真打勾。

只要有一條踩雷沒處理好，就不建議拿去給客戶 or 真實使用者用。

坑 1：把 API Key 直接給別人看

常見踩雷行為：

- 把 Key 直接貼在程式碼裡，截圖給同學 / 貼上社群問問題
- 把 Key 打進 ChatGPT：「這是我的 key，你幫我串好」
- 把有 Key 的檔案丟進 GitHub、雲端硬碟公開資料夾

自我檢查 (請打勾)：

- ☐ 我沒有在任何程式碼裡看到類似 sk-xxxx 這種字樣被我貼給別人看
- ☐ 我沒有把 Key 直接丟給 AI 看 (ChatGPT、其他模型都一樣)
- ☐ 我 debug 用的截圖或影片裡，看不到我的 Key
- ☐ 如果我已經不小心貼出去，我知道要去把舊的 Key 刪掉，重新生成

坑 2：以為「只有我看得到」→ 其實是公開環境

常見踩雷行為：

- 以為 GitHub 預設是私人的，其實是公開 repo
- 以為「分享網址」只有同學看得到，沒意識到任何拿到連結的人都行
- 把 demo 網址貼在社團，貼文下面，沒檢查裡面有沒有敏感資訊

自我檢查：

- 我知道我放程式碼的地方，是「公開」還是「私人」
- 如果是公開的地方，我裡面沒有放 API Key、密碼或客戶資料
- 我有檢查過 demo 畫面上，沒有真實姓名、電話、email 等個資
- 我清楚知道：「只要丟上網的東西，有機會被任何人看到」

坑 3：分不清「玩具練習」跟「正式產品」

常見踩雷行為：

- 練習做出一個小工具，就想拿去給公司直接用
- 沒有任何備份、沒有測試流程，卻被同事、客戶當正式系統使用
- 自己也說不清楚：「這個東西壞掉了會影響到誰？」

自我檢查：

- 我可以清楚說出：這個東西現在是「玩具還是 demo」還是「正式用」
- 如果它壞掉，我知道會影響到哪些人（只有我？還是客戶？）
- 如果是給別人用，我有想過：我要怎麼跟對方說「有可能會壞」
- 我不會跟別人說「你就放心用吧」除非我真的有測過、備份過

坑 4：搞不清前端 / 後端，以為 Key 藏在前端就安全

常見踩雷行為：

- 在瀏覽器裡寫 JS，直接把 Key 放在那邊呼叫 API
- 以為「使用者看不到程式碼」，所以把 Key 藏在某個檔案就好
- 不知道開發者工具可以直接看到前端程式碼、API 請求內容

自我檢查：

- 我知道「前端」就是跑在瀏覽器、用戶電腦上的那一邊
- 我沒有在前端程式碼裡寫 API Key
- 我知道要放 Key 的地方，應該是「後端」或平台提供的環境變數

- 如果我說不清「這段 code 跑在誰的電腦上」，我暫時不會把 Key 放進去

坑 5：真實資料直接拿來當練習素材

常見踩雷行為：

- 把公司 Excel、客戶名單、報表直接丟給 AI 或丟進 demo 系統
- 用真實顧客 email / 訂單資料當測試，還拿來當示範畫面
- 存取到資料庫後，沒有先問清楚「哪些資料可以碰、哪些不行」

自我檢查：

- 我知道「真實客戶資料」不適合作為練習素材
- 我用的是假資料、或經過模糊處理（改過名字、刪掉關鍵欄位）
- 如果資料不是我的（是公司 / 客戶的），我有先問過能不能用
- 我願意為我丟給 AI 的資料負責（如果不願意，就不要丟）

坑 6：搞不清誰在為這個系統負責

常見踩雷行為：

- AI 幫我寫完，我就覺得完成任務，沒想過「出事找誰」
- 同事或客戶在用你的東西出問題，你說：「那是 AI 寫的」
- 沒有任何紀錄：「現在線上跑的是哪一版？」

自我檢查：

- 我知道，這個專案的 Owner 是誰（就算是我自己，也要講得出來）
- 我接受一個現實：AI 只是一個工具，責任還是在人身上
- 如果我要給別人用，我至少有一段話可以說明「目前限制與風險」
- 我不會在完全沒測過的情況下，讓陌生人直接大量使用

坑 7：成本與用量完全沒概念

常見踩雷行為：

- 覺得「反正現在在測試，用量應該不多啦」
- 做了一個會一直呼叫 API 的流程，沒設上限也沒設停損
- 接上外部服務（郵件、簡訊）卻不知道每次呼叫都在花錢

自我檢查：

- ☐ 我知道這個系統用了哪些「要錢的服務」（例如：LLM、簡訊、郵件）
- ☐ 我有大概估過：「如果一天有 100 個人用，大概會花多少錢？」
- ☐ 我有設某種「上限」或「暫停開關」（就算是手動也好）
- ☐ 如果是公司的錢，我有先跟相關的人講清楚可能的成本範圍

坑 8：問 AI 問題時，把公司機密、合約全丟進去

常見踩雷行為：

- 直接把完整合約、內部策略文件貼給公開的 AI 模型
- 用公司帳號傳高度敏感的內容給各種第三方工具
- 沒搞清楚：現在用的這個 AI，是公司允許的、還是自己亂裝的

自我檢查：

- ☐ 我知道「極機密的文件」不會直接丟給任何外部服務處理
- ☐ 如果公司有指定要用哪個 AI 工具，我就只用那個處理內部文件
- ☐ 我有把文件中最敏感的部分先遮掉或刪掉再拿來問問題
- ☐ 我有想過：「如果這份內容外流，我願不願意負責？」

最後，請至少勾過這三條：

- ☐ 我沒有公開我的 API Key，也沒有把 Key 放在前端程式碼裡
- ☐ 我目前做的東西，只拿來「練習 / demo」，沒有假裝它是正式產品
- ☐ 牽涉到真實資料、真實使用者或真實金流，我會先停下來問專業的人